TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Drupal Commerce Core access-bypass flaw exploited in the wild

From **Cybersecurity Briefing - 2026-10-30** · 2026-10-29 to 2026-10-30 (last 24 hours; Indianapolis and State of Indiana swept back to 2026-10-25) · Briefing generated 2026-10-30

REPORT ID	VERSION	HANDLING
CTI-20261030-02	1.0 · 2026-10-30 10:06 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-28	2026-10-30
CVES	**ANALYST**	
CVE-2026-118539	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-10-28 the Drupal Security Team published SA-CONTRIB-2026-254 for Commerce Core, the contributed module that adds carts, checkout and commerce APIs to Drupal sites. The advisory rates the flaw Highly critical (21/25, risk string AC:None/A:None/CI:Some/II:Some/E:Exploit/TD:All) and says it is being actively exploited in the wild [S1]. The CVE record, CVE-2026-118539, classifies it as CWE-862 Missing Authorization enabling forceful browsing (CAPEC-87). It carries no CVSS score yet [S2]. Certain routes and entity fields are not properly protected, so a caller can view or change commerce data they should not reach. Drupal warns this may cause financial harm to merchants [S1] [S3] [S4].

The excerpt's version ranges overlap the fixed release. The advisory and the structured CVE data settle this: versions below 2.41 are affected, as are versions from 3.0.0 up to but not including 3.3.13. The fixes are 8.x-2.41 (Drupal ^9.3/^10) and 3.3.13 (Drupal ^10.3/^11), both released on 2026-10-28 [S1] [S2] [S6] [S7]. Those releases also fix five lower-severity Commerce Core advisories (SA-CONTRIB-2026-255 to -259) [S6] [S7]. Drupal 7 sites on the 1.x branch are outside the advisory and get no fixes, because Drupal 7 support has ended [S8]. Reported usage is about 42,000 sites: roughly 13,000 on 2.x, 17,000 on 3.x and 12,000 on the unsupported 1.x branch [S3] [S8].

Drupal has not described the attacks, the attackers or the scale of exploitation, and no indicators of compromise have been published [S1] [S3] [S4]. A patch analysis by Ostorlab [S9] describes the mechanism. Commerce entities had entity-level access checks but no field-level ones. As a result, reference, ownership, price, state and payment fields on products, variations, coupons, promotions, orders, order items and payment methods could be changed through JSON:API/REST or forms. A coupon

autocomplete route leaked coupon codes, and some order admin routes did not require commerce admin permission. That analysis comes from the fix and its tests, not from observed attacks. It also says some takeover paths need a low-privilege account, which is less severe than Drupal's AC:None rating. CVE-2026-118539 was not in CISA KEV as of the 2026-10-29 catalog, and FIRST had no EPSS score [S5] [S9] [S10].

Next steps: upgrade every Drupal Commerce site to 3.3.13 or 8.x-2.41 now, run database updates and clear caches. Then audit orders, coupons, promotions and variations for tampering, as Drupal advises, and review web logs for JSON:API/REST writes to commerce entities. Drupal 7 Commerce sites need a migration plan or a compensating control such as a WAF or restricted access, because no fix will come [S1] [S8] [S9].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
Exploitation of unpatched Commerce Core 2.x and 3.x sites will very likely grow over the next two weeks. Public fix diffs and patch analyses make it easy to work out the vulnerable JSON:API and route paths. [S1] [S6] [S9]

LIKELY · MODERATE CONFIDENCE
Most abuse will likely be financial (price, coupon or order manipulation and coupon-code harvesting) rather than remote code execution, because the bug lets attackers change data but does not run code. [S1] [S2] [S9]

LIKELY · LOW CONFIDENCE
CISA will likely add CVE-2026-118539 to KEV within 30 days, given Drupal's confirmation of exploitation and CISA's past KEV listings for exploited Drupal flaws. [S1] [S3] [S10]

VERY UNLIKELY · MODERATE CONFIDENCE
Drupal 7 Commerce 1.x sites are very unlikely to receive an official fix, which leaves about 12,000 sites dependent on compensating controls or migration. Whether the 1.x code has the same flaw has not been established. [S8]

INDICATORS OF COMPROMISE

Drupal and the press reports published no indicators of compromise (no IPs, hashes or request signatures) as of 2026-10-30. Every entry below is derived. Each one is a location or request pattern from the patch analysis [S9] and standard Drupal routing that an attacker would have to use, so treat them as hunting leads, not confirmed attacker infrastructure.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`PATCH /jsonapi/commerce_product_variation/{bundle}/{uuid} (body changes relationships.product_id)`	Derived. The patch analysis shows variations could be reassigned to another product by editing product_id. In Drupal JSON:API, resources follow /jsonapi/{entity_type}/{bundle}. A 2xx response on a vulnerable version from a non-admin account is suspicious.	DERIVED		[S9]
http-request	`PATCH /jsonapi/commerce_promotion_coupon/{bundle}/{uuid} (body changes promotion_id)`	Derived. The patch analysis describes moving a coupon to another promotion by changing its promotion reference. After the fix this returns 403.	DERIVED		[S9]
http-request	`PATCH/POST /jsonapi/commerce_order/{bundle}/{uuid} or /jsonapi/commerce_order_item/{bundle}/{uuid} touching uid, state, total_price, adjustments, unit_price, purchased_entity, order_items or coupons`	Derived. These order and order-item fields are now restricted because they could previously be changed without authorization. Use them to look for price or ownership tampering.	DERIVED		[S9]
http-request	`GET /entity_reference_autocomplete/commerce_promotion_coupon/*`	Derived. The patch analysis says the coupon entity autocomplete route listed coupon codes to any caller. Drupal core's standard autocomplete path is /entity_reference_autocomplete/{target_type}/... Repeated anonymous requests suggest coupon harvesting.	DERIVED		[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`GET /jsonapi/commerce_product_variation/{bundle}?filter[...]`	Derived. JSON:API collection filters could reveal hidden variations, such as those of unpublished products. High-volume filtered enumeration is a hunting lead.	DERIVED		[S9]
http-request	`Requests to /admin/commerce/orders/{order}/* (for example, the coupon management form entity.commerce_order.manage_coupons_form) from users without the 'access commerce administration pages' permission`	Derived. The fix adds that permission requirement to the order admin routes. The exact URL paths depend on the site's route configuration.	DERIVED		[S9]
other	`Commerce Core version < 8.x-2.41 or 3.0.0-3.3.12 in composer.lock (package drupal/commerce)`	Derived exposure indicator for asset inventory, based on the advisory's affected ranges.	DERIVED		[S1] [S2]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

Commerce Core enforced access at the entity level but not on individual fields, and several routes lacked permission checks [S1] [S9]. A remote caller can send direct requests (forceful browsing) to JSON:API/REST endpoints or forms to read hidden data, such as coupon codes from an autocomplete route or unpublished variations through collection filters. The caller can also change reference, ownership, price, state or payment fields on orders, order items, coupons, promotions and variations [S2] [S9]. The likely outcome is financial loss: altered order totals, coupons applied from unrelated promotions, reassigned products and harvested discount codes. Drupal has not described the observed attacks, and nothing indicates code execution [S1] [S3] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Sends crafted requests to unprotected Commerce Core routes and JSON:API/REST endpoints on internet-facing Drupal stores. [S1] [S2] [S9]	Web/WAF logs showing non-admin or anonymous POST/PATCH requests to /jsonapi/commerce_* or to commerce admin routes that receive 2xx responses.
Discovery	T1083 File and Directory Discovery	Forceful browsing (CAPEC-87) to find and enumerate commerce routes, coupon autocomplete results and hidden variations through JSON:API filters. ATT&CK has no exact web-route equivalent, so this mapping is approximate. [S2] [S9]	High rates of requests to /entity_reference_autocomplete/commerce_promotion_coupon/ and filtered /jsonapi/commerce_product_variation collection queries from a single source.

Tactic	Technique	Procedure observed	Detection opportunity
Collection	T1213 Data from Information Repositories	Harvests coupon codes and non-public product or variation data from the commerce data store. [S9]	Coupon codes appearing in redemptions with no matching marketing distribution; large autocomplete response volumes.
Impact	T1565.001 Data Manipulation: Stored Data Manipulation	Changes order/order-item price, adjustments, state or owner fields, reassigns variations or coupons, and triggers deletions that remove other parents' entities, causing financial loss to the merchant. [S1] [S9]	Order audits that compare totals against the line-item and catalog prices; orders whose state changed with no payment; variations whose product_id owner differs from the creator.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

JSON:API writes to Drupal Commerce entities `SPLUNK SPL`

```
index=web (sourcetype=access_combined OR sourcetype=nginx:plus:access) (method=POST OR method=PATCH OR method=DELETE) uri_path="/jsonapi/commerce_*"
| stats count min(_time) as first max(_time) as last values(status) as statuses values(uri_path) as paths by src_ip, http_user_agent
| where count > 5 OR match(statuses, "^20")
| sort - count
```

Most storefronts do not take JSON:API writes from the public. Adjust for decoupled front ends that use JSON:API legitimately, and correlate with authenticated user IDs in the Drupal watchdog log.

Coupon autocomplete harvesting `KQL`

```
AzureDiagnostics
| where Category == "ApplicationGatewayAccessLog" or Category == "FrontDoorAccessLog"
| where requestUri_s has "/entity_reference_autocomplete/commerce_promotion_coupon"
| summarize Requests=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated) by clientIP_s,
userAgent_s, httpStatus_d
| where Requests > 10
| order by Requests desc
```

Field names differ between WAF and CDN log sources. Anonymous access to this route is unexpected.

Commerce JSON:API tampering attempt `SURICATA`

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"Possible Drupal Commerce CVE-2026-118539 field
tampering via JSON:API"; flow:established,to_server; http.method; pcre:"/^(PATCH|POST)$/"; http.uri;
content:"/jsonapi/commerce_"; http.request_body;
pcre:"/(product_id|promotion_id|total_price|unit_price|adjustments|\"uid\"|\"state\")/"; classtype:web-
application-attack; sid:9118539; rev:1;)
```

Requires TLS inspection or deployment behind the TLS terminator. Expect false positives on legitimate decoupled checkouts.

Order price inconsistency audit `SPLUNK SPL`

```
index=drupal_db sourcetype=commerce_order
| eval line_total=tonumber(sum_unit_price_x_qty), order_total=tonumber(total_price__number)
| where abs(order_total - line_total - tonumber(adjustment_total)) > 0.01 OR order_total <= 0
| table order_id uid state order_total line_total adjustment_total changed
```

Illustrative only. It assumes order data has been exported into Splunk. An equivalent SQL query against the commerce_order and commerce_order_item tables can carry out Drupal's advice to audit orders for inconsistencies.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Drupal Commerce Core (drupal/commerce) 2.x	< 8.x-2.41	8.x-2.41 (2026-10-28; Drupal ^9.3/^10)	CVE-2026-118539	Not assigned (Drupal risk 21/25, Highly critical)	Not available (FIRST returned no record on 2026-10-30)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Drupal Commerce Core (drupal/commerce) 3.x	>= 3.0.0, < 3.3.13	3.3.13 (2026-10-28; Drupal ^10.3/^11)	CVE-2026-118539	Not assigned (Drupal risk 21/25, Highly critical)	Not available (FIRST returned no record on 2026-10-30)	No	N/A
Drupal Commerce 1.x (Drupal 7)	Not covered by advisory; vulnerability status unknown	None (Drupal 7 end of life)	N/A	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Inventory all Drupal sites under management and check composer.lock for the drupal/commerce version. Flag 2.x below 2.41 and 3.x below 3.3.13. `IT OPS` [S1] [S2]
- Upgrade to Commerce Core 3.3.13 (composer require 'drupal/commerce:^3.3') or 8.x-2.41 (composer require 'drupal/commerce:^2.41'), then run database updates (drush updb) and clear caches (drush cr). Reapply any custom patches. `IT OPS` [S1] [S6] [S7] [S9]
- Search web and WAF logs since at least 2026-10-28 (and earlier if retained) for JSON:API/REST writes to commerce entities and anonymous coupon autocomplete requests. `SOC` [S9]
- If patching is delayed, block or restrict /jsonapi/commerce_* write methods and /entity_reference_autocomplete/commerce_promotion_coupon at the WAF or reverse proxy. `IT OPS` [S9]

Short term (1–7 days)

- Audit orders, as Drupal advises. Check that totals match line items and adjustments, look for unexpected owner or state changes, coupons applied from unrelated promotions, and variations reassigned to other products. `SOC` [S1] [S9]
- Rotate or invalidate active coupon codes that could have been harvested, and review recent coupon redemption spikes. `IT OPS` [S9]
- Reconcile payments with the payment gateway for orders created or changed since 2026-10-28, and notify affected merchants or clients of any financial discrepancies. `LEADERSHIP` [S1]
- Check contributed and custom modules that add their own commerce reference fields, since the patch analysis says these must add their own restrictions. `IT OPS` [S9]

Long term

- Migrate remaining Drupal 7 / Commerce 1.x stores to a supported platform. They receive no security fixes. `LEADERSHIP` [S8]

- Subscribe to Drupal security advisories and set a same-day patch SLA for Highly critical contributed-module advisories. `LEADERSHIP` [S1] [S3]
- Turn off the JSON:API and REST modules on storefronts that do not need a decoupled front end, or make them read-only. `IT OPS` [S9]

Workarounds & compensating controls

- Add WAF rules to allow only expected JSON:API/REST methods and paths, and require authentication on commerce write endpoints. `IT OPS` [S9]
- Add automated daily order-integrity checks and alerts on zero-value or under-priced orders. `SOC` [S1]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Drupal Security Team: Commerce Core - Highly critical - Access bypass - SA-CONTRIB-2026-254
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory; confirms active exploitation, ranges and fixes.

[S2] CVE Program (Drupal CNA): CVE-2026-118539 record
Published 2026-10-30 · `A1` Completely reliable, confirmed by other sources
CWE-862, CAPEC-87; no CVSS; structured ranges use lessThan 2.41 / 3.3.13.

[S3] BleepingComputer: Drupal warns of critical Commerce Core flaw exploited in attacks
Published 2026-10-30 · `B2` Usually reliable, probably true
Briefing source; restates advisory; 42,000+ site figure. Its version ranges read as inclusive of fixed versions.

[S4] The Hacker News: Hackers Actively Exploit Highly Critical Drupal Commerce Core Authorization Bypass Flaw
Published 2026-10-30 · `B2` Usually reliable, probably true
Briefing source; no details on attack activity.

[S5] FIRST: EPSS API query for CVE-2026-118539
Published 2026-10-30 · `A6` Completely reliable, truth cannot be judged
Returned no data; CVE too new for scoring.

[S6] Drupal.org: Commerce 3.3.13 release
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Lists SA-CONTRIB-2026-254 to -259 fixed.

[S7] Drupal.org: Commerce 8.x-2.41 release
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Previous 2.x release was 8.x-2.40 (2024-08-22).

[S8] ITdaily: 30,000 Drupal web shops potentially vulnerable to actively exploited access flaw
Published 2026-10-30 · **C2** Fairly reliable, probably true
Per-branch usage counts (as of 18 Oct) apparently from drupal.org project usage; notes Drupal 7 1.x not covered.

[S9] Ostorlab: Drupal Commerce Access Bypass, Exploited in the Wild (CVE-2026-118539)
Published 2026-10-30 · **C3** Fairly reliable, possibly true
Patch-diff analysis of restricted fields and routes; not based on observed attacks. Suggests some paths need a low-privilege account, which differs from Drupal's AC:None.

[S10] CISA: Known Exploited Vulnerabilities Catalog (JSON feed, version 2026.10.29)
Published 2026-10-29 · **A2** Completely reliable, probably true
CVE not seen in the newest entries of catalog 2026.10.29. Only part of the feed was reviewed; S9 independently reports it was not listed.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2024-08-22	Commerce 8.x-2.40 released (last 2.x release before the fix).	[S7]
2026-10-18	Drupal.org usage snapshot: about 42,002 sites using Commerce Core across 1.x, 2.x and 3.x.	[S8]
2026-10-28	Drupal publishes SA-CONTRIB-2026-254 (Highly critical, exploited) and releases Commerce 3.3.13 and 8.x-2.41. The CVE is reserved and made public the same day.	[S1] [S2] [S6] [S7]
2026-10-29	CISA KEV catalog 2026.10.29 does not list CVE-2026-118539.	[S10] [S9]
2026-10-30	CVE record published to CVE services without CVSS. BleepingComputer and The Hacker News report the exploitation.	[S2] [S3] [S4]

Relevance to Indianapolis, Indiana & managed clients

Drupal is common in Indiana public-sector, higher-education and nonprofit web estates, and Commerce Core is the usual way such sites take payments for registrations, event tickets, permits, campus stores, donations and merchandise. Indiana universities and colleges, county and municipal agencies, healthcare foundations and small and mid-size manufacturers or retailers with Drupal storefronts should confirm whether drupal/commerce is installed, including on forgotten microsites. The risk is mainly financial and to data integrity: altered order totals, abused coupons and possible exposure of order or payment-method metadata. For entities handling cardholder data, that can raise PCI DSS questions. Managed IT service clients often run sites built by outside agencies that the client never patches. Providers should scan hosted Drupal instances for vulnerable Commerce versions, patch on a same-day basis, and give clients a short order-audit checklist. Any remaining Drupal 7 Commerce stores should be flagged as unsupported and put behind WAF restrictions until they are migrated.

Intelligence gaps

- No details on the observed exploitation: attacker identity, targeting, scale, request patterns or start date are all unreported.
- No indicators of compromise have been published by Drupal or any threat-intel vendor.
- No CVSS score from the CNA or NVD, and no EPSS score yet.
- Not in KEV yet; watch for a CISA addition and due date.
- Unclear whether exploitation needs any account. Drupal's risk string says AC:None, but the patch analysis suggests some paths need a low-privilege account.
- Whether the unsupported Commerce 1.x (Drupal 7) branch has the same flaw.
- Details and exploitation status of the companion advisories SA-CONTRIB-2026-255 to -259 fixed in the same releases.

Other notes

- The briefing excerpt and the press articles give affected ranges as '0.0.0 through 2.41' and '3.0.0 through 3.3.13', which appear to include the fixed versions. The advisory and the CVE structured data use strict less-than bounds, so 2.41 and 3.3.13 are fixed [S1] [S2].
- Site counts vary between reports: 42,000+ across all branches [S3] versus about 30,000 on the 2.x and 3.x branches the advisory covers [S8].
- This comes during a busy period for Drupal and PHP flaws. BleepingComputer cites an exploited Drupal core SQL injection (CVE-2026-9082, added to KEV in May 2026) and two Drupal RCE fixes about two weeks earlier (CVE-2026-108097, CVE-2026-108099). The Hacker News notes ongoing exploitation of the PHP2Shell flaws (CVE-2026-109618/109619). These were not independently verified for this report [S3] [S4].
- Some third-party CVE aggregators list the CVE as 'not known to be exploited', which contradicts Drupal's own statement. The vendor advisory takes precedence.

CTI-20261030-02 v1.0 · Generated 2026-10-30 10:06 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.